応用情報技術者試験　テクノロジ系　No.11

セキュリティ

情報セキュリティ・情報セキュリティ管理・セキュリティ技術評価・情報セキュリティ対策・セキュリティ実装技術

目次

1. 11-1 情報セキュリティ（53語）
2. 11-2 情報セキュリティ管理（16語）
3. 11-3 セキュリティ技術評価（4語）
4. 11-4 情報セキュリティ対策（31語）
5. 11-5 セキュリティ実装技術（6語）
6. まとめ

11-1 情報セキュリティ まとめ表

情報セキュリティの3要素（CIA）	
要素	**意味**
機密性（Confidentiality）	許された人だけが使える
完全性（Integrity）	正しく、改ざんされていない
可用性（Availability）	必要なときに使える

暗号方式の比較		
方式	**鍵**	**特徴**
共通鍵暗号（AES）	送る側と受ける側で同じ鍵	速い。鍵の受け渡しが課題
公開鍵暗号（RSA・楕円曲線）	公開鍵で暗号化、秘密鍵で復号	遅いが鍵の配送が楽

11-1 情報セキュリティ 基本と暗号

共通鍵暗号方式
Symmetric Key Cryptography

暗号化と復号に同じ鍵を使う方式

ポイント n人がお互いに通信するには n(n−1)/2 個の鍵が要る。代表はAES

公開鍵暗号方式
Public Key Cryptography

公開鍵と秘密鍵の組を使う方式

ポイント 受信者の公開鍵で暗号化し、受信者の秘密鍵で復号する。n人なら2n個

ハイブリッド暗号
Hybrid Encryption

共通鍵を公開鍵暗号で送り、データ本体は共通鍵で暗号化する方式

ポイント TLSで使う

ハッシュ関数
Hash Function

データから決まった長さの値を作る関数

ポイント 元に戻せない、同じ値になる別のデータを見つけにくい。改ざんの検出に使う。例: SHA-256

ディジタル署名
Digital Signature

送信者が自分の秘密鍵で署名し、受信者が送信者の公開鍵で確かめるしくみ

ポイント 送信者の本人確認と改ざんの検出ができる

PKI
ぴーけーあい / Public Key Infrastructure

認証局（CA）が公開鍵の持ち主を証明するしくみ

ポイント ディジタル証明書は認証局の秘密鍵で署名される。失効した証明書はCRLやOCSPで確かめる

Public Key＝公開鍵／Infrastructure＝基盤

11-1 情報セキュリティ 基本と暗号・攻撃の手口

MAC
めっく / Message Authentication Code

共通鍵とデータから作る値で、改ざんを検出する符号

Message＝メッセージ／Authentication＝認証／Code＝符号

ランサムウェア
Ransomware

データを暗号化して使えなくし、元に戻す代わりに金銭を要求するマルウェア

ポイント 対策はオフラインのバックアップ

クロスサイトスクリプティング
XSS / Cross-Site Scripting

Webページに不正なスクリプトを埋め込み、閲覧者のブラウザで実行させる攻撃

ポイント 対策は出力時のエスケープ処理

標的型攻撃
Targeted Attack

特定の組織をねらい、本物らしいメールでマルウェアを送り込む攻撃

ポイント APT（長い期間にわたる攻撃）もある

SQLインジェクション
SQL Injection

入力にSQL文の一部を入れて、データベースを不正に操作する攻撃

ポイント 対策はプレースホルダ（バインド機構）

CSRF
しーさーふ / Cross-Site Request Forgery

ログイン中の利用者に、意図しない処理の要求を送らせる攻撃

ポイント 対策はトークンの確認

Cross-Site＝サイトをまたいだ／Request＝要求／Forgery＝偽造

11-1 情報セキュリティ 攻撃の手口

DDoS攻撃
Distributed Denial of Service Attack

多くの機器から大量の通信を送り、サービスを止める攻撃

Distributed＝分散した／Denial of Service＝サービス妨害

DNSキャッシュポイズニング
DNS Cache Poisoning

DNSサーバに偽の情報を覚えさせ、偽のサイトに誘導する攻撃

中間者攻撃
MITM / Man-in-the-Middle Attack

通信の間に割り込んで、盗み見や改ざんをする攻撃

ゼロデイ攻撃
Zero-day Attack

修正プログラムが出る前に、その弱点（脆弱性）をねらう攻撃

パスワードリスト攻撃
Password List Attack

ほかのサイトから漏れたIDとパスワードの組で、ログインを試す攻撃

ポイント パスワードの使い回しが原因

ソーシャルエンジニアリング
Social Engineering

人の心のすきをついて、パスワードなどを聞き出す手口

例 電話でなりすます、肩越しにのぞく

11-1 情報セキュリティ 攻撃の手口・基本と暗号（発展）

サイドチャネル攻撃
Side-channel Attack

処理の時間や消費電力などを測って、暗号の鍵を推測する攻撃

機密性・完全性・可用性
CIA / Confidentiality, Integrity, Availability

許された人だけが見られること、正しく改ざんされていないこと、使いたいときに使えること

ポイント 情報セキュリティの3要素

真正性・責任追跡性・否認防止・信頼性
Authenticity / Accountability / Non-repudiation / Reliability

本物であること、誰がしたかをたどれること、後から否定できないこと、意図どおり動くこと

ポイント 3要素に加えて求められる性質

AES
えーいーえす / Advanced Encryption Standard

現在よく使われる共通鍵暗号

ポイント 鍵の長さは128・192・256ビット

RSA
あーるえすえー

大きな数の素因数分解が難しいことを利用した公開鍵暗号

ポイント 考えた3人の名前の頭文字

楕円曲線暗号
ECC / Elliptic Curve Cryptography

楕円曲線の計算の難しさを使う公開鍵暗号

ポイント RSAより短い鍵で同じ強さ

11-1 情報セキュリティ 基本と暗号（発展）

SHA-256
しゃー256

256ビットのハッシュ値を作るハッシュ関数

ポイント 改ざんの検出に使う

認証局
CA / Certification Authority

公開鍵が本人のものであることを証明する電子証明書を発行する機関

電子証明書
Digital Certificate

公開鍵とその持ち主を結び付け、認証局が署名したデータ

ポイント X.509という形式

CRL
しーあーるえる / Certificate Revocation List

期限前に無効になった証明書の一覧

ポイント 今はOCSPでその場で確かめる方法もある

タイムスタンプ
Time Stamp

ある時刻に電子データが存在し、その後変わっていないことを証明する仕組み

鍵管理
Key Management

暗号の鍵を作る・配る・保管する・捨てるまでを安全に管理すること

11-1 情報セキュリティ 基本と暗号（発展）・攻撃の手口（発展）

危殆化
きたいか / Compromise

暗号の鍵が漏れたり、暗号が破られたりして安全でなくなること

耐量子計算機暗号
PQC / Post-Quantum Cryptography

量子コンピュータでも破られにくい暗号

フィッシング
Phishing

本物そっくりの偽のメールやサイトで、IDやパスワードをだまし取る攻撃

ビジネスメール詐欺
BEC / Business Email Compromise

取引先や上司になりすましたメールで、お金を振り込ませる詐欺

水飲み場型攻撃
Watering Hole Attack

狙う相手がよく見るWebサイトを改ざんし、ウイルスに感染させる攻撃

ドライブバイダウンロード
Drive-by Download

Webサイトを見ただけで、知らないうちにウイルスを入れられる攻撃

11-1 情報セキュリティ 攻撃の手口（発展）

ブルートフォース攻撃
総当たり攻撃 / Brute Force Attack

パスワードを、すべての組合せで試す攻撃

辞書攻撃
Dictionary Attack

よく使われる言葉をパスワードとして順に試す攻撃

リバースブルートフォース攻撃
Reverse Brute Force Attack

パスワードを1つに決めて、IDを次々に変えて試す攻撃

ポイント アカウントのロックをすり抜けやすい

レインボーテーブル攻撃
Rainbow Table Attack

ハッシュ値と元の文字列の対応表を使って、パスワードを割り出す攻撃

ポイント ソルトを加えると防ぎやすい

バッファオーバフロー攻撃
Buffer Overflow Attack

用意された領域より大きなデータを送り込み、不正な命令を動かす攻撃

ディレクトリトラバーサル
Directory Traversal

「../」などを使って、公開していないファイルを読み出す攻撃

11-1 情報セキュリティ 攻撃の手口（発展）

OSコマンドインジェクション
OS Command Injection

入力欄にOSの命令を混ぜて、サーバで勝手に実行させる攻撃

セッションハイジャック
Session Hijacking

ログイン中の利用者のセッションIDを盗み、なりすます攻撃

クリックジャッキング
Clickjacking

透明なページを重ね、利用者に意図しない所をクリックさせる攻撃

ボット・C&Cサーバ
Bot / Command and Control Server

乗っ取られて攻撃者の命令で動くコンピュータと、命令を出すサーバ

サプライチェーン攻撃
Supply Chain Attack

守りの弱い取引先やソフトウェアの部品を足がかりにして、狙う組織を攻める攻撃

APT
えーぴーてぃー / Advanced Persistent Threat

特定の組織を長い期間ねばり強く狙い続ける攻撃

Advanced＝高度な／Persistent＝しつこい／Threat＝脅威

11-1 情報セキュリティ 攻撃の手口（発展）

ポートスキャン
Port Scan

どのポートが開いているかを調べること

ポイント 攻撃の下調べに使われる

踏み台攻撃
Stepping Stone Attack

他人のコンピュータを乗っ取り、そこから別の相手を攻撃すること

内部不正
Insider Threat

社員や関係者が、情報を持ち出したり壊したりすること

ポイント 不正のトライアングル（動機・機会・正当化）

SYNフラッド攻撃
SYN Flood Attack

接続の要求（SYN）を大量に送り、サーバの資源を使い切らせる攻撃

シャドーIT
Shadow IT

会社が認めていない機器やクラウドを、社員が勝手に仕事に使うこと

11-2 情報セキュリティ管理 まとめ表

リスク対応の4つ	
対応	**意味**
リスク回避	原因となる活動をやめる
リスク低減	対策をして起こる確率や影響を小さくする
リスク移転（共有）	保険や外部委託で他者と分け合う
リスク保有（受容）	影響が小さいので受け入れる

11-2 情報セキュリティ管理 管理のしくみ

ISMS
あいえすえむえす / Information Security Management System

組織で情報セキュリティを管理するしくみ

ポイント JIS Q 27001。PDCAで改善する

Information Security=情報セキュリティ／Management System=管理の仕組み

リスクアセスメント
Risk Assessment

リスクを特定・分析・評価すること

リスク対応
Risk Treatment

評価したリスクに、回避・低減・移転・保有のどれで対応するかを決めること

情報セキュリティポリシ
Information Security Policy

組織の情報セキュリティの方針と規則

ポイント 基本方針・対策基準・実施手順の3階層

CSIRT
しーさーと / Computer Security Incident Response Team

セキュリティ事故（インシデント）に対応する組織

Computer Security=コンピュータの安全／Incident=事故／Response=対応／Team=チーム

SOC
そっく / Security Operation Center

ネットワークを24時間監視して、攻撃を見つける組織

Security=安全／Operation=運用／Center=拠点

11-2 情報セキュリティ管理 管理のしくみ・管理のしくみ（発展）

サイバーセキュリティ経営ガイドライン
Cyber Security Management Guidelines

経営者がセキュリティ対策を進めるために経済産業省とIPAが示した指針

脅威・脆弱性
Threat / Vulnerability

損害を与えるきっかけと、そのつけ込まれる弱点

残留リスク
Residual Risk

対策をした後にも残るリスク

情報資産
Information Asset

守るべき価値のある情報や、それを扱う機器・ソフトウェアなど

リスク回避・低減・移転・保有
Risk Avoidance / Reduction / Transfer / Acceptance

やめる、対策で小さくする、保険などでほかに移す、受け入れる

ポイント リスク対応の4つの方法

個人情報保護
Personal Information Protection

個人を特定できる情報を、決めた目的の範囲で安全に扱うこと

ポイント プライバシーマークの制度がある

11-2 情報セキュリティ管理 管理のしくみ（発展）

インシデント
Incident

情報セキュリティを損なうおそれのある出来事

BCP
びーしーぴー / Business Continuity Plan

災害や事故のときにも、大事な業務を続けたり早く戻したりするための計画

Business＝事業／Continuity＝継続／Plan＝計画

JPCERT/CC
JPCERTコーディネーションセンター

日本のインシデントの情報を集めて調整する組織

J-CRAT・J-CSIP
Cyber Rescue and Advice Team / Initiative for Cyber Security Information sharing Partnership

IPAの、標的型攻撃の被害を相談できる窓口と、企業どうしで攻撃の情報を共有する取組み

11-3 セキュリティ技術評価 評価の基準

CVSS
しーぶいえすえす / Common Vulnerability Scoring System

脆弱性の深刻さを0〜10の点数で表す共通の基準

Common＝共通の／Vulnerability＝脆弱性／Scoring＝点数付け／System＝方式

ISO/IEC 15408
コモンクライテリア / Common Criteria

IT製品のセキュリティ機能を評価する国際規格

ペネトレーションテスト
Penetration Test

実際に攻撃してみて、侵入できるかを確かめるテスト

ファジング
Fuzzing

予想外のデータを大量に与えて、ソフトウェアの脆弱性を見つける方法

11-4 情報セキュリティ対策 技術的な対策

多要素認証
Multi-factor Authentication

知識（パスワード）・所持（スマホ）・生体（指紋）のうち、2種類以上を組み合わせる認証

ファイアウォール
Firewall

通信を、決めたルールで通したり止めたりする装置

DMZ
でぃーえむぜっと / DeMilitarized Zone

外部と内部のネットワークの間に置く、公開サーバ用の区域

DeMilitarized＝非武装の／Zone＝地帯

WAF
わふ / Web Application Firewall

Webアプリへの攻撃（SQLインジェクションやXSS）を、通信の中身を見て防ぐ装置

Web Application＝Webアプリ／Firewall＝防火壁

IDS・IPS
Intrusion Detection / Prevention System

IDSは不正な侵入を見つけて知らせる、IPSは見つけて止める

Intrusion＝侵入／Detection＝検知／Prevention＝防止

EDR
いーでぃーあーる / Endpoint Detection and Response

パソコンなどの端末で不審な動きを見つけ、すぐに対応するしくみ

Endpoint＝端末／Detection＝検知／Response＝対応

11-4 情報セキュリティ対策 技術的な対策・管理的・物理的な対策

SIEM
しーむ / Security Information and Event Management

いろいろな機器のログをまとめて分析し、攻撃を見つけるしくみ

Security＝安全／Information＝情報／Event＝出来事／Management＝管理

ゼロトラスト
Zero Trust

社内のネットワークでも信用せず、すべてのアクセスを毎回確かめる考え方

デジタルフォレンジックス
Digital Forensics

事故の後、法的な証拠になるようにログやデータを集めて分析すること

最小権限の原則
Principle of Least Privilege

仕事に必要な最小限の権限だけを与えること

セキュアブート
Secure Boot

起動するとき、署名を確かめて正しいソフトウェアだけを動かすしくみ

TPM
てぃーぴーえむ / Trusted Platform Module

鍵の生成や保管を安全に行う、耐タンパ性のあるチップ

Trusted＝信頼された／Platform＝基盤／Module＝部品

11-4 情報セキュリティ対策 技術的な対策（発展）

ソルト
Salt

パスワードをハッシュにする前に加える、ランダムな文字列

ポイント 同じパスワードでも違うハッシュ値になる

ストレッチング
Stretching

ハッシュの計算を何回も繰り返し、総当たりにかかる時間を増やすこと

ワンタイムパスワード
One-time Password

1回しか使えないパスワード

ポイント 盗まれても次には使えない

生体認証
Biometric Authentication

指紋・顔・静脈など体の特徴で本人を確かめる方法

ポイント 本人を拒否する率と他人を受け入れる率の釣り合いが大事

シングルサインオン
SSO / Single Sign-On

1回のログインで、複数のシステムを使えるようにする仕組み

ポイント SAMLやOpenID Connectを使う

リスクベース認証
Risk-based Authentication

いつもと違う場所や端末からのログインのときだけ、追加の確認をする認証

11-4 情報セキュリティ対策 技術的な対策（発展）

CAPTCHA
きゃぷちゃ

ゆがんだ文字を読ませるなどして、人間かプログラムかを見分ける仕組み

サンドボックス
Sandbox

怪しいプログラムを、外に影響しない隔離した環境で動かして調べる仕組み

パターンマッチング方式
Pattern Matching

既知のウイルスの特徴（シグネチャ）と比べて見つける方式

ポイント 新しいウイルスには弱い

ビヘイビア法
Behavior Method

プログラムの動きを見て、怪しい振る舞いからウイルスを見つける方式

検疫ネットワーク
Quarantine Network

社内につなぐ前に、パソコンが安全かを隔離した場所で確かめる仕組み

UTM
ゆーてぃーえむ / Unified Threat Management

ファイアウォール・IPS・ウイルス対策などを1台にまとめた機器

11-4 情報セキュリティ対策 技術的な対策（発展）・管理的・物理的な対策（発展）

MDM
えむでぃーえむ / Mobile Device Management

会社のスマートフォンなどをまとめて管理する仕組み

ポイント なくしたときに遠隔でデータを消せる

DLP
でぃーえるぴー / Data Loss Prevention

大事な情報が外に出ていかないように見張り、止める仕組み

DNSSEC
でぃーえぬえすせっく

DNSの応答に電子署名を付けて、偽の応答を見分ける仕組み

OP25B
おーぴーにじゅうごびー / Outbound Port 25 Blocking

迷惑メールを防ぐため、家庭などから外への25番ポートの通信を止める仕組み

入退室管理
Physical Access Control

ICカードなどで、建物や部屋に入る人を管理すること

ポイント 前の人について入る共連れを防ぐ

クリアデスク・クリアスクリーン
Clear Desk / Clear Screen

机の上に書類を置いたままにせず、離席するときは画面をロックすること

11-4 情報セキュリティ対策 管理的・物理的な対策（発展）

セキュリティ教育
Security Awareness Training

社員に攻撃の手口や守り方を教えること

ポイント 標的型メールの訓練など

11-5 セキュリティ実装技術 安全な通信と開発

TLS
てぃーえるえす / Transport Layer Security

通信を暗号化し、サーバの正しさを証明書で確かめるプロトコル

ポイント HTTPSで使う。ハンドシェイクで暗号方式と鍵を決める

Transport Layer=トランスポート層／Security=安全

IPsec
あいぴーせっく / IP Security

IPの層で暗号化と認証を行うプロトコル

ポイント VPNに使う。トンネルモードとトランスポートモード

SPF・DKIM・DMARC

送信元のなりすましを防ぐメールの認証技術

ポイント SPFは送信元のIPアドレス、DKIMは電子署名で確かめる。DMARCは結果に応じた扱いを決める

S/MIME
えすまいむ / Secure MIME

公開鍵を使って、メールを暗号化・署名する方式

Secure=安全な／MIME=メールの形式の規格

セキュアプログラミング
Secure Programming

脆弱性を作らないようにプログラムを書くこと

ポイント 入力のチェック、エスケープ、プレースホルダなど

無線LANのセキュリティ
WPA3

無線LANの暗号化の規格

ポイント WEPは弱く使ってはいけない

まとめ（1/3） この分野で覚える用語

小分類	用語
11-1 情報セキュリティ	共通鍵暗号方式・公開鍵暗号方式・ハイブリッド暗号・ハッシュ関数・ディジタル署名・PKI・MAC・標的型攻撃・ランサムウェア・SQLインジェクション・クロスサイトスクリプティング・CSRF・DDoS攻撃・DNSキャッシュポイズニング・中間者攻撃・ゼロデイ攻撃・パスワードリスト攻撃・ソーシャルエンジニアリング・サイドチャネル攻撃・機密性・完全性・可用性・真正性・責任追跡性・否認防止・信頼性・AES・RSA・楕円曲線暗号・SHA-256・認証局・電子証明書・CRL・タイムスタンプ・鍵管理・危殆化・耐量子計算機暗号・フィッシング・ビジネスメール詐欺・水飲み場型攻撃・ドライブバイダウンロード・ブルートフォース攻撃・辞書攻撃・リバースブルートフォース攻撃・レインボーテーブル攻撃・バッファオーバフロー攻撃・ディレクトリトラバーサル・OSコマンドインジェクション・セッションハイジャック・クリックジャッキング・ボット・C&Cサーバ・サプライチェーン攻撃・APT・ポートスキャン・SYNフラッド攻撃・踏み台攻撃・シャドーIT・内部不正

まとめ（2/3） この分野で覚える用語

小分類	用語
11-2 情報セキュリティ管理	ISMS・リスクアセスメント・リスク対応・情報セキュリティポリシ・CSIRT・SOC・サイバーセキュリティ経営ガイドライン・情報資産・脅威・脆弱性・リスク回避・低減・移転・保有・残留リスク・個人情報保護・インシデント・BCP・JPCERT/CC・J-CRAT・J-CSIP
11-3 セキュリティ技術評価	CVSS・ISO/IEC 15408・ペネトレーションテスト・ファジング

まとめ（3/3） この分野で覚える用語

小分類	用語
11-4 情報セキュリティ対策	多要素認証・ファイアウォール・DMZ・WAF・IDS・IPS・EDR・SIEM・ゼロトラスト・デジタルフォレンジックス・最小権限の原則・セキュアブート・TPM・ソルト・ストレッチング・ワンタイムパスワード・生体認証・シングルサインオン・リスクベース認証・CAPTCHA・サンドボックス・パターンマッチング方式・ビヘイビア法・検疫ネットワーク・UTM・MDM・DLP・DNSSEC・OP25B・入退室管理・クリアデスク・クリアスクリーン・セキュリティ教育
11-5 セキュリティ実装技術	TLS・IPsec・SPF・DKIM・DMARC・S/MIME・セキュアプログラミング・無線LANのセキュリティ